

LAB 10 — FIREWALL CONFIGURATION: IPTABLES

Default-Deny Policy, Rule Authoring, Host Blocking & Drop Logging

CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 29, 2026

1. Lab Overview

This lab demonstrates host-based firewall configuration using iptables, the standard Linux packet filtering framework. The lab covers default-deny policy implementation, stateful connection tracking, service allowlisting, host-specific blocking, and drop logging — core skills for hardening Linux systems in enterprise and government environments.

Field	Detail
Tool	iptables v1.8.11 (nf_tables backend)
Platform	Kali Linux — 192.168.40.7 (eth0)
Target Host Blocked	Metasploitable2 — 192.168.40.3
Default Policy	INPUT: DROP FORWARD: DROP OUTPUT: ACCEPT
Rules Applied	8 rules across INPUT chain
Drop Log	IPT-DROP: prefix via dmesg / kernel log
ATT&CK; Relevance	T1562.004 (Disable/Modify Firewall), T1040, T1046

2. Baseline Firewall State (Pre-Configuration)

Before applying rules, all three chains were set to ACCEPT with no rules — a completely open firewall state typical of a default Kali installation.

```
$ sudo iptables -L -v -n
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
```

3. Applied Firewall Ruleset

Rules were authored as a documented bash script (/etc/iptables/lab10_rules.sh) for repeatability and version control. This is the production-standard approach — ad hoc iptables commands are lost on reboot.

Order	Rule	Action	Security Rationale
1	Default INPUT policy	DROP	Default-deny — block all inbound traffic not explicitly permitted. Industry best practice.

2	Default FORWARD policy	DROP	Prevent packet forwarding — this host is not a router.
3	Default OUTPUT policy	ACCEPT	Allow all outbound traffic — analyst workstation needs unrestricted egress.
4	Loopback interface (lo)	ACCEPT	Required for local services (DNS resolver, DBs) that bind to 127.0.0.1.
5	ESTABLISHED / RELATED connections	ACCEPT	Stateful tracking — allow return traffic for outbound sessions initiated by this host.
6	TCP port 22 inbound	ACCEPT	Allow SSH administrative access. In production, restrict to known admin IPs.
7	TCP port 80 inbound	ACCEPT	Allow HTTP — required if host serves web content.
8	TCP port 443 inbound	ACCEPT	Allow HTTPS — encrypted web traffic.
9	Source: 192.168.40.3 (Metasploitable2)	DROP	Block all inbound traffic from known vulnerable host — prevents exploitation attempts.
10	ICMP echo-request (ping)	ACCEPT	Allow ping for network diagnostic purposes.
11	All remaining INPUT traffic	LOG	Log all dropped packets with IPT-DROP: prefix for forensic analysis.

4. Post-Configuration Firewall State

```
Chain INPUT (policy DROP 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
0 0 ACCEPT all -- lo * 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT all -- * * 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
0 0 ACCEPT tcp -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:22
0 0 ACCEPT tcp -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:80
0 0 ACCEPT tcp -- * * 0.0.0.0/0 0.0.0.0/0 tcp dpt:443
0 0 DROP all -- * * 192.168.40.3 0.0.0.0/0
0 0 ACCEPT icmp -- * * 0.0.0.0/0 0.0.0.0/0 icmp type 8
0 0 LOG all -- * * 0.0.0.0/0 0.0.0.0/0 LOG prefix "IPT-DROP: "
Chain FORWARD (policy DROP 0 packets, 0 bytes)
Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
```

5. Drop Log Analysis — Real Traffic Caught

The IPT-DROP logging rule immediately began capturing real dropped traffic. The following packets were caught within minutes of rule application:

```
[ 3964.178803] IPT-DROP: IN=eth0 SRC=140.82.114.26 DST=192.168.40.7
PROTO=TCP SPT=443 DPT=39698 ACK PSH
[ 3965.676909] IPT-DROP: IN=eth0 SRC=140.82.114.26 DST=192.168.40.7
PROTO=TCP SPT=443 DPT=39698 ACK PSH
... (9 total drop events from 140.82.114.26:443)
```

Field	Value	Analysis
Source IP	140.82.114.26	GitHub CDN/API server — packets from github.com HTTPS service
Source Port	443 (HTTPS)	Return traffic from a previous outbound GitHub connection
Destination	192.168.40.7:39698	Kali machine — ephemeral port from earlier git push/pull session
Flags	ACK PSH / ACK FIN	Return data packets and connection teardown — expected GitHub HTTPS flow

Root cause	State table expiry	ESTABLISHED rule missed these packets because the connection state entry expired between the outbound request and the return traffic arriving
Threat level	None – benign	GitHub return traffic is expected and legitimate. No malicious activity.

Analyst Note: This is a real-world firewall tuning scenario. The drop log revealed that a prior git push created an outbound HTTPS session to GitHub. When the state table entry expired before return packets arrived, those packets were treated as unsolicited inbound traffic and dropped. In production, this would require either increasing conntrack timeout values or adding a specific ACCEPT rule for return traffic from known trusted hosts.

6. MITRE ATT&CK; Mapping

Technique ID	Name	Tactic	Lab Relevance
T1562.004	Impair Defenses: Disable/Modify Firewall	Defense Evasion	This lab demonstrates what attackers target — disabling iptables rules is a common post-exploitation step to enable C2 callbacks. Understanding rule structure enables defenders to detect unauthorized changes.
T1040	Network Sniffing	Credential Access	Default-deny INPUT policy prevents an attacker who gains local access from receiving unsolicited inbound C2 traffic on arbitrary ports.
T1046	Network Service Discovery	Discovery	The host-block rule for 192.168.40.3 prevents Metasploitable2 from probing Kali's open ports — limiting attacker reconnaissance from a compromised host.
T1048	Exfiltration Over Alternative Protocol	Exfiltration	OUTPUT ACCEPT policy is intentionally permissive for this lab. In a hardened production environment, OUTPUT rules would also restrict exfiltration channels.

7. Analyst Findings

Default-deny is the correct baseline posture: Setting INPUT policy to DROP and explicitly allowing only required services (SSH, HTTP, HTTPS, ICMP) follows the principle of least privilege at the network layer. Every port not listed is implicitly blocked — reducing attack surface without maintaining a per-port blocklist.

Stateful connection tracking is essential: The ESTABLISHED/RELATED rule is what makes a default-deny policy functional for outbound traffic. Without it, return packets for outbound connections would be dropped, breaking all web browsing, git operations, and package updates. The GitHub drop log demonstrated this exact failure mode when state table entries expired.

Drop logging provides immediate forensic value: The IPT-DROP log captured real external traffic within minutes of rule application — demonstrating that even in a lab environment, unsolicited inbound connection attempts are constant. In production, this log feeds SIEM systems for threat detection.

Rule scripts enable auditability and repeatability: Documenting rules as a bash script (/etc/iptables/lab10_rules.sh) rather than running ad hoc commands creates an auditable change record, enables version control via Git, and allows rules to survive reboots when combined with iptables-restore in a startup script.